LINUX VULNERABILITY - XZ UTILITY BACKDOOR

Team Members: Addam Narru, Nur Puteri Fazmira, Muhammad Luqman, Muhammad Solihin, Abdullah Nasser

Lecturer: Encik Khairul Amin Mohamad Sukri

Introduction

The Open Worldwide Application Security Project, better known as OWASP, is a well-known non-profit organization dedicated to making web applications and software more secure. They offer a ton of free resources, tools, guides, and documentation to help developers and companies understand security risks and actually prevent them.

OWASP matters a lot because almost everything we use today runs on web applications—and hackers know that. By following OWASP's recommendations, developers can build much safer systems and avoid a lot of common headaches.

OWASP Top 10 is a list of the considered critical security risks that can bring harm to web applications. Often developers, bug bounty, security teams, and companies around the world use it as a go-to reference to spot the biggest vulnerabilities because it helps strengthen their defences against cyberattacks.

The OWASP Top 10 isn't a fixed list that never changes. It gets updated every 3 to 4 years to reflect new technologies, emerging threats, and the latest tactics attackers are using. This regular refresh keeps everyone aware of the real, current risks so they can protect their applications effectively

Risk Description

Software supply chain failures occur when there are security weaknesses during the process of developing, building, distributing, or updating software. This usually happens when a system relies on external tools, libraries, or third-party code that may contain vulnerabilities or be modified maliciously. If organizations do not properly verify these components or fail to apply strong access control and the principle of least privilege, development tools, update servers, or third-party libraries and insert malicious code into the software before it is

distributed to users. When the software is installed or updated, the malicious code is also installed without users realizing it, allowing attackers to compromise the system.

Case Study

XZ Utils or XZ for short is an open-source data compression tool that has been developed since 2005 and primarily maintained by a single developer from Finland, Lasse Collin. It is used by almost every single major Linux distribution due to how well it does its job. However, due to the relatively low amount of attention and help the project receives, it doesn't get very frequent updates and doesn't receive much support despite being a critical project in most Linux distributions.

A bad actor dubbed "Jia Tan" recognized this weakness and launched a social engineering attack by using multiple accounts to pressure Lasse to update faster and introduced himself as the solution by helping him and lightening his burden. After 2 years of gaining his trust and helping with maintaining the project, he sneaked in his code that if allowed through, gave him remote access to almost every Linux distribution that is infected with the compromised XZ tool.

Fortunately, this attempt was caught by Andres Freund, a Microsoft software engineer from Germany. While testing PostgreSQL, a database software on an unstable version of Debian that contains the backdoor, he notices a strange consistent slowdown of about 400-500ms. This incident fits the description of the “A03: Software Supply Chain Failures” in OWASP Top 10 2025 Report. This backdoor targets XZ or to be specific the library called liblzma, which is a library used by OpenSSH, an open-source tool that allows users to log into, manage, and execute commands on remote computers without flagging any anti-virus.

Although OpenSSH doesn’t directly depend on liblzma, some Linux distributions were bundling it in a way that allowed the malicious code to activate whenever OpenSSH was used. This is a classic supply chain attack — compromising a lower-level library so it could eventually affect higher-level, widely used tools like OpenSSH.

Prevention

This CVE is highly sophisticated supply chain backdoor that targets SSH access on Linux system, according to Cybersecurity and Infrastructure Security Agency (CISA) they suggest downgrading the utility to a stable version, such as 5.4.6.

Furthermore, this backdoor specifically targets 64-bit Linux systems, particularly in SSH processes, so restricting SSH Access or blocking the port 22 can prevent this exploitation. Moreover, for a long-term protection leveraging multi-layer zero trust security is essential in today's cybersecurity to further tighten our security.

Lastly, it is recommended that updating our software to the latest patch but sometimes by practicing "just-in-time" update can also prevent this kind of backdoor. Let the security researchers vet the new code first.

References

1. OWASP Top Ten | OWASP Foundation. (2024). Owasp.org. https://owasp.org/www-project-top-ten/?utm_source=chatgpt.com
2. Understanding Red Hat's response to the XZ security incident. (n.d.). Www.redhat.com. https://www.redhat.com/en/blog/understanding-red-hats-response-xz-security-incident
3. Group, I. (2024, April). XZ Utils Backdoor — Everything You Need to Know, and What You Can Do. Akamai; Akamai Technologies. https://www.akamai.com/blog/security-research/critical-linux-backdoor-xz-utils-discovered-what-to-know
4. A03 Software Supply Chain Failures - OWASP Top 10:2025 RC1. (2025). Owasp.org. https://owasp.org/Top10/2025/A03_2025-Software_Supply_Chain_Failures/
5. Khanna, A. (2024, October 23). *Andres Freund: the man who saved Internet.* Medium. https://medium.com/@projectcsework/andres-freund-the-man-who-saved-internet-b9de192c63e9